FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

4 of the organisation's 21 first-priority fraud schemes remain open, most of them in digital and identity, and 1 control reported in place is not supported in practice.

78.5 / 100 STRUCTURED

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

Assessment date · 11 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL OWNER-MANAGED FIRM

WHAT DOES THE ASSESSMENT SHOW?

Fraud readiness at a glance

78.5
READINESS SCORE OUT OF 100

Structured
MATURITY BAND

6
DOMAINS ASSESSED

100.00
STRONGEST DOMAIN
Finance, banking & financial reporting

16.00
WEAKEST DOMAIN
Digital, cyber-enabled & identity fraud

The review asked about 49 fraud schemes that apply to the organisation. For 36, every control that stops the scheme was reported in place. 10 have at least one such control reported as a gap. 1 relies on a control reported in place whose own supporting practices were reported as gaps. The figures above are test fixtures for this fictional demonstration, not an approved score.

Domain readiness profile

Digital, cyber-enabled and identity fraud	16.00	Reactive
Ethics, integrity and anti-corruption	86.70	Strategic
Detection, speak-up and response	86.70	
Fraud governance and accountability	90.00	
Fraud risk assessment	91.70	
Finance, banking and financial reporting	100.00	

Ordered weakest first. Overall readiness 78.5 / 100.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHY DOES THE POSITION LOOK LIKE THIS?

What is driving the position

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Digital, cyber-enabled and identity fraud: 4 first-priority schemes open	Multi-factor on all email **Not in place** Email never enough on its own **Not in place** Verification for calls, voice notes and video **Partly**	Most business email compromise starts with an account that has no multi-factor authentication. The same area also leaves open: a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed.
Code accessible to staff: reported in place, not supported by its practices	Code accessible to staff **In place** Training on joining **Partly**	It is relied on to stop the scheme where staff do not know or understand what is expected. One self-reported answer says it is in place; the answers about the practices it depends on say otherwise.

THE PATTERN THAT MATTERS

Of 24 controls reported fully in place that the method can cross-check, 5 were cross-checked with one further self-reported answer about a practice they depend on: 5 consistent. The other 19 were not cross-checked and nothing is concluded about them. These cross-checks compare the organisation's own answers; they are not tests of operation and they change no figure.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHERE DOES FRAUD EXPOSURE MATTER MOST?

Priority fraud schemes

#	PRIORITY EXPOSURE	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	PRIORITY ORDER
1	**A payment instruction received by email is acted on** Acting on payment instructions received by email is how business email compromise succeeds.	Email never enough on its own **Not in place**	Payments, credit or goods released to someone impersonating a supplier, customer, employee or executive.	Put in place: email never enough on its own.	**Priority 1** First-priority scheme; 1 of the 1 controls answered is a gap.
2	**An email account is taken over** Most business email compromise starts with an account that has no multi-factor authentication.	Multi-factor on all email **Not in place**	Payments, credit or goods released to someone impersonating a supplier, customer, employee or executive.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	**Priority 2** First-priority scheme; 1 of the 1 controls answered is a gap.
3	**A cloned voice or video instruction is obeyed** Voices and faces can be cloned, so only an agreed verification method holds.	Verification for calls, voice notes and video **Partly** Pressure triggers verification **Partly** Changes to call-back details verified **Partly**	Payments, credit or goods released to someone impersonating a supplier, customer, employee or executive.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.	**Priority 3** First-priority scheme; 4 of the 4 controls answered are gaps.
4	**A security compromise is not notified** POPIA section 22 requires notification as soon as reasonably possible.	Compromises reported as POPIA requires **Partly** Affected people warned **Not in place**	Records, payments or assets changed by someone with more access than their role needs.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	**Priority 4** First-priority scheme; 2 of the 2 controls answered are gaps.

Ordered by the draft method's scheme priority and the number of controls reported as gaps. The order indicates where to act first; it is not a risk rating.

HOW COULD THAT EXPOSURE MATERIALISE?

How the schemes would work here

A payment instruction received by email is acted on

Changed details or urgent payments are processed on the strength of an email › Email never enough on its own not in place › Business email compromise and payment redirection

Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds. Here, payment changes received by email are acted on as received.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

Warning signs: Business email compromise and payment redirection · Takeover of staff accounts

An email account is taken over

A mailbox without strong sign-in is used to send or intercept payment instructions › Multi-factor on all email not in place › Takeover of staff accounts

A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication. Here, email accounts are protected by passwords only.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

Warning signs: Takeover of staff accounts · Business email compromise and payment redirection · Spoofed or lookalike email in the organisation's name

A cloned voice or video instruction is obeyed

A caller who sounds or looks like a known person is believed › Verification for calls, voice notes and video partly › Deepfake voice and video impersonation of executives and staff

A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds. Here, some staff check unusual requests, depending on their own judgement; pressure triggers verification: partly.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.

Warning signs: Deepfake voice and video impersonation of executives and staff · Business email compromise and payment redirection · Takeover of staff accounts

These are plausible schemes for an organisation with the controls it reported. They are not allegations that these events have occurred.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHAT DOES MANAGEMENT NEED TO CHANGE?

What management should change

#	MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
1	**Email never enough on its own**	Stops the scheme where a payment instruction received by email is acted on. Its control is a gap today.	Head of IT or IT provider	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
2	**Multi-factor on all email**	Stops the scheme where an email account is taken over. Its control is a gap today.	Head of IT or IT provider	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
3	**Verification for calls, voice notes and video and pressure triggers verification**	Stops the scheme where a cloned voice or video instruction is obeyed. 4 of its controls are gaps today.	Head of IT or IT provider, with the CFO and head of IT together	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used.
4	**Compromises reported as POPIA requires and affected people warned**	Stops the scheme where a security compromise is not notified. 2 of its controls are gaps today.	Head of IT or IT provider, with the head of IT or information security	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
5	**Confirm the 1 other unsupported controls**	1 further control is reported in place while practices it relies on were reported as gaps.	Each process owner named in the supporting register	Every control relied on to stop a first-priority scheme is supported by the practices it depends on, confirmed by the person who runs it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHAT SHOULD HAPPEN IN THE FIRST 90 DAYS?

The first 90 days

30 days: Contain and complete the picture

0–30 DAYS

Owners are named and the most exposed schemes are contained.

Name one accountable executive for each area with first-priority schemes open or unsupported: digital and identity (4).

CEO or company secretary

A signed list of schemes, their accountable executives and target dates.

Complete when: Every first-priority scheme has a named executive and a date.

Close the scheme where an email account is taken over: put in place multi-factor on all email.

Head of IT or IT provider

The email security report showing multi-factor status for every account, including shared mailboxes.

Complete when: Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

Close the scheme where a payment instruction received by email is acted on: put in place email never enough on its own.

Head of IT or IT provider

The written rule, staff communication, call-back records for a sample of requests.

Complete when: Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

60 days: Close the first-priority gaps

31–60 DAYS

The controls that stop the first-priority schemes operate for every case.

Close the scheme where a cloned voice or video instruction is obeyed: put in place verification for calls, voice notes and video, pressure triggers verification, changes to call-back details verified and gift cards and PIN requests banned.

CFO and head of IT together

The verification procedure, briefing records for executives, simulation results.

Complete when: Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.

Close the scheme where a security compromise is not notified: put in place compromises reported as POPIA requires and affected people warned.

Head of IT or information security

The breach response procedure, notification templates, records of past notifications.

Complete when: Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.

90 days: Extend and embed

61–90 DAYS

Second-priority schemes are addressed and the scheme status is reported each month.

Confirm with HR lead or ethics officer how code accessible to staff operates and put in place training on joining.

HR lead or ethics officer

HR lead or ethics officer confirms in writing that the controls operate for every case.

Complete when: Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?

Have the owners receive the status of the 4 first-priority schemes each month until they are closed.

CEO or company secretary

The first monthly scheme status.

Complete when: Three monthly scheme status reports received and minuted.

HOW WILL MANAGEMENT KNOW WHETHER READINESS IS IMPROVING?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Email never enough on its own	Payment changes received by email are acted on as received.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
Multi-factor on all email	Email accounts are protected by passwords only.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
Verification for calls, voice notes and video	Some staff check unusual requests, depending on their own judgement.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
Compromises reported as POPIA requires	A compromise would be handled as it happens, without a set process.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
Controls reported in place but unsupported	1 of the controls reported in place.	Each confirmed by its process owner, with its practices in place.

Management conclusion

Fictional Owner-Managed Firm is not starting from zero: 36 schemes have every control that stops them reported in place. The work is concentrated. 4 first-priority schemes, most of them in digital and identity, need the specific controls named in this report, owned by the people the method names for them. Management should also not rely on the control reported in place whose own practices were reported as gaps until its owner confirms how it works.

This report is based on the organisation's own answers to the MK Fraud Readiness review, given by the respondent and the accountable functions named in it, and read against the draft review method, which MK has not yet approved. MK has not independently tested whether controls operate in practice, and no evidence was reviewed; evidence review is a separate Advisory service. TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.